

CyberHeros — Writeup

Target IP: 10.128.130.106

Category: Web Exploitation / Client-Side Logic Flaw

Difficulty: Easy

1. Reconnaissance

Scansione iniziale con Nmap per identificare porte e servizi attivi sul target:

```
nmap -sS -sV 10.128.130.106
```

Risultato:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.48 ((Ubuntu))
|_http-title: CyberHeros : Index
```

```
(kali㉿kali)-[~]
└─$ nmap -sS -sVC 10.128.130.106
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-14 10:25 +0200
Nmap scan report for 10.128.130.106
Host is up (0.037s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 3072 04:e9:51:69:3b:d1:00:99:63:e9:0b:96:54:b4:40:64 (RSA)
| 256 31:08:6d:bc:3a:2c:05:7e:d0:43:ad:6b:68:23:4c:90 (ECDSA)
|_ 256 2f:db:a2:ad:60:f6:59:3e:34:80:b4:09:8c:ae:5d:43 (ED25519)
80/tcp    open  http     Apache httpd 2.4.48 ((Ubuntu))
|_http-title: CyberHeros : Index
|_http-server-header: Apache/2.4.48 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.79 seconds
```

Due porte aperte:

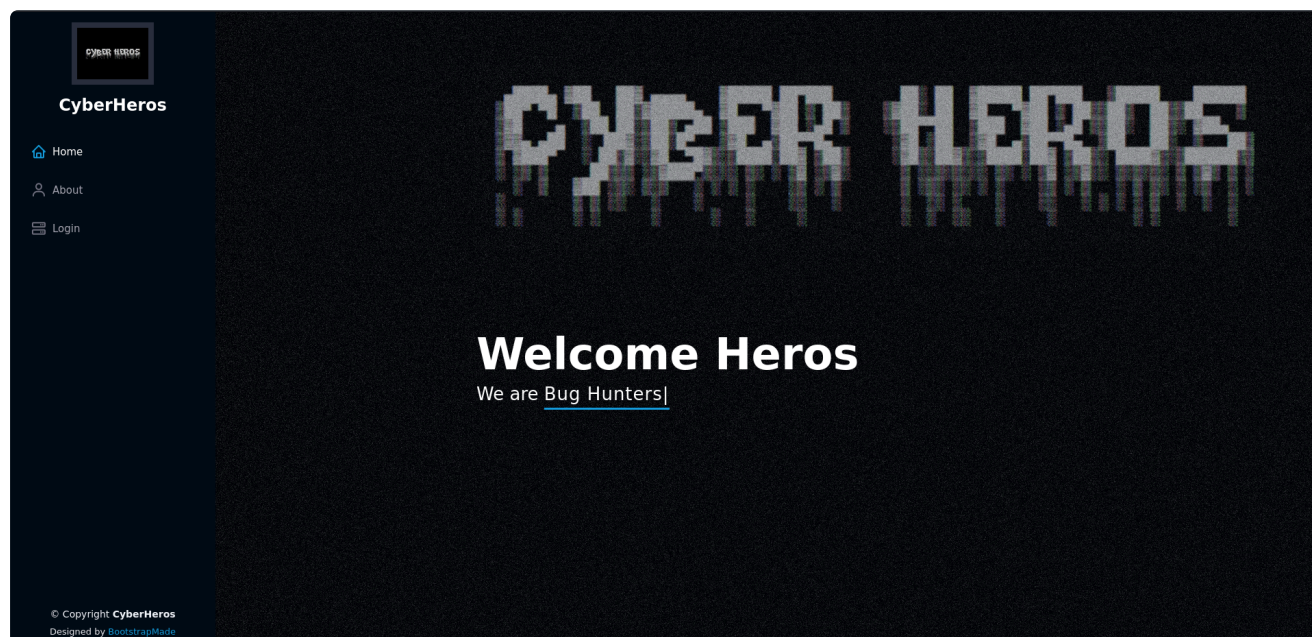
- **22/tcp** — SSH (OpenSSH 8.2p1)
- **80/tcp** — HTTP (Apache 2.4.48), con titolo pagina "CyberHeros : Index"

Dato che la porta 80 espone un sito web con un titolo esplicito, si parte da lì.

2. Enumerazione Web

Visitando `http://10.128.130.106` si trova la homepage del sito **CyberHeros**, una landing page a tema "Bug Hunters" con un menu laterale:

- Home
- About
- Login



La sezione **Login** invita esplicitamente l'utente a "dimostrare le proprie capacità di hacking":

Show your hacking skills and login to became a CyberHero ! :D

Un chiaro invito ad analizzare la logica di autenticazione lato client, dato che si tratta presumibilmente di un form gestito interamente in JavaScript (nessun backend di autenticazione vero e proprio visibile a questo punto).

3. Analisi del codice sorgente

Ispezionando il sorgente della pagina di login (view-source / DevTools), si trova la funzione JavaScript `authenticate()` che gestisce il controllo delle credenziali:

```
function authenticate() {
  a = document.getElementById('uname')
  b = document.getElementById('pass')
  const ReverseString = str => [...str].reverse().join('');
  if (a.value=="h3ck3rBoi" & b.value==ReverseString("54321@terceSrepuS")) {
    var xhttp = new XMLHttpRequest();
    xhttp.onreadystatechange = function() {
      if (this.readyState == 4 && this.status == 200) {
```

```

        document.getElementById("flag").innerHTML = this.responseText;
        document.getElementById("todel").innerHTML = "";
    }
};
xhttp.open("GET",
"RandomLo0o0o0o0o0o0o0o0o0gpath12345_Flag_"+a.value+"_"+b.value+".txt",
true);
xhttp.send();
}
else {
    alert("Incorrect Password, try again.. you got this hacker !");
}
}

```

```

122
123 <script>
124 function authenticate() {
125     a = document.getElementById('uname')
126     b = document.getElementById('pass')
127     const ReverseString = str => [...str].reverse().join('');
128     if (a.value=="h3ck3rBoi" & b.value==ReverseString("54321@terceSrepuS")) {
129         var xhttp = new XMLHttpRequest();
130         xhttp.onreadystatechange = function() {
131             if (this.readyState == 4 && this.status == 200) {
132                 document.getElementById("flag").innerHTML = this.responseText ;
133                 document.getElementById("todel").innerHTML = "";
134                 document.getElementById("rm").remove() ;
135             }
136         };
137         xhttp.open("GET", "RandomLo0o0o0o0o0o0o0o0o0gpath12345_Flag_"+a.value+"_"+b.value+".txt", true);
138         xhttp.send();
139     }
140     else {
141         alert("Incorrect Password, try again.. you got this hacker !")
142     }

```

Punti chiave individuati:

1. **Username hardcoded:** h3ck3rBoi , visibile in chiaro nel codice client-side.
2. **Password offuscata tramite reverse string:** la password non è scritta direttamente, ma viene confrontata con l'output di una funzione che **inverte** la stringa "54321@terceSrepuS" .
3. **Vulnerabilità di design:** l'intera logica di autenticazione (credenziali comprese) è eseguita ed esposta interamente lato client — chiunque ispezioni il sorgente può ricavare le credenziali senza alcun bruteforce.

Deoffuscamento della password

Invertendo manualmente la stringa 54321@terceSrepuS :

```

Input:   5 4 3 2 1 @ t e r c e S r e p u S
Reverse: S u p e r S e c r e t @ 1 2 3 4 5

```

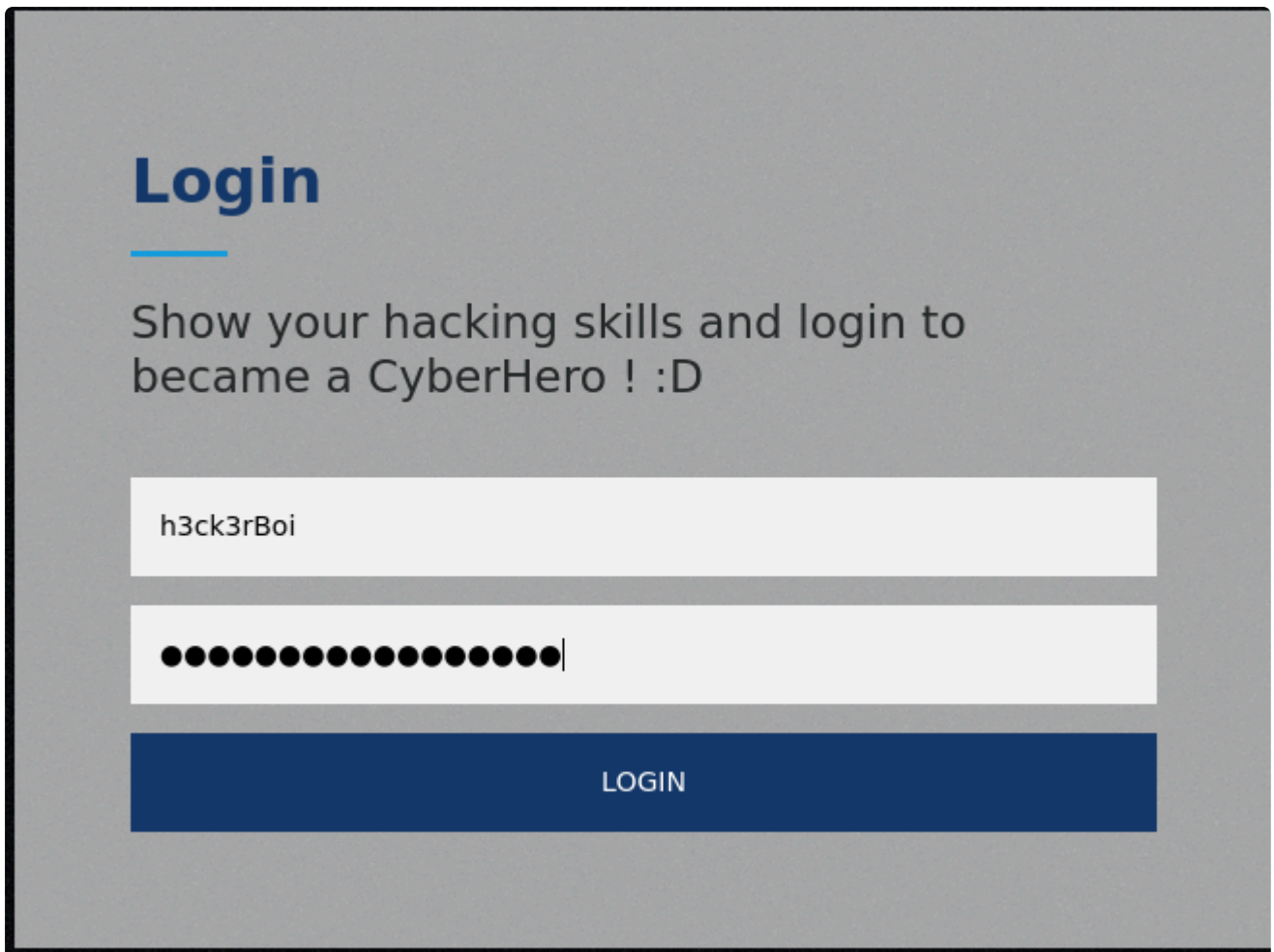
Password ricavata: SuperSecret@12345

4. Sfruttamento

Con le credenziali ricostruite:

Campo	Valore
Username	h3ck3rBoi
Password	SuperSecret@12345

Si effettua il login sulla pagina `/login` , compilando i campi con le credenziali ricavate:



Il form invia una richiesta GET verso un endpoint con nome offuscato/randomico (`RandomLo0o0o0o0o0o0o0o0o0o0gpath12345_Flag_h3ck3rBoi_SuperSecret@12345.txt`), che restituisce il contenuto del flag direttamente nella pagina.

5. Flag

```
Congrats Hacker, you made it !! Go ahead and nail other challenges as well
:D
flag{edb0be532c540b1a150c3a7e85d2466e}
```

```
Congrats Hacker, you made it !! Go ahead  
and nail other challenges as well :D  
flag{eddb0be532c540b1a150c3a7e85d2466e}
```

6. Considerazioni finali

Questa macchina illustra un classico esempio di **vulnerabilità da autenticazione client-side**: qualsiasi logica di validazione (anche se "offuscata" con trucchi come l'inversione di stringa) che gira interamente nel browser è per definizione ispezionabile e bypassabile dall'utente, indipendentemente da quanto complesso sembri l'offuscamento.

Lezione principale: l'autenticazione — comprese le credenziali stesse — non deve mai essere implementata o verificata lato client. Il server deve sempre essere l'unica fonte di verità per il controllo degli accessi.

Strumenti usati: `nmap` , browser DevTools / view-source.